

# **SIGO-OLLAS**

Sistema de Gestión de Ollas Comunes

## **Informe de Validación y Pruebas de QA**

Curso Integrador II – Software | Junio 2026

# 1. Introducción

Este documento presenta el plan de validación y pruebas de calidad (QA) del proyecto SIGO-OLLAS, un Sistema de Gestión de Ollas Comunes desarrollado para digitalizar y optimizar la administración de comedores comunitarios en el Perú.

El sistema está diseñado específicamente para lideresas de ollas comunes en zonas rurales o de conectividad inestable. Por esta razón, las pruebas priorizan los siguientes escenarios reales de uso:

- Viewport de 360px de ancho (dispositivos Android de gama baja)
- Tiempo de carga visual inicial (FCP) menor a 1.8 segundos en redes lentas o 3G
- Funcionamiento completo en modo offline con sincronización automática al recuperar conexión (PWA Offline-First)

La aplicación es una Progressive Web App (PWA) instalable en el dispositivo móvil, sin necesidad de publicar en tiendas de aplicaciones. Esto garantiza actualizaciones inmediatas y menor consumo de almacenamiento en dispositivos de recursos limitados.

# 2. Tecnologías y Herramientas de Prueba

| ID         | Historia | Descripción de la Prueba                                                                               | Suite                   | Herramienta      | Resultado |
|------------|----------|--------------------------------------------------------------------------------------------------------|-------------------------|------------------|-----------|
| Vitest     | Backend  | Framework principal para pruebas funcionales y de interoperabilidad del backend (Express + TypeScript) | Funcional / Integración | Node.js 22       | PASS      |
| Playwright | Frontend | Framework E2E para pruebas de interfaz de usuario en vistas web y móvil (Next.js)                      | E2E / PWA Offline       | Headless Browser | PASS      |
| Lighthouse | Frontend | Auditoría automatizada de accesibilidad, rendimiento, SEO y buenas prácticas (WCAG 2.1 AA)             | Usabilidad              | JSX AST Parser   | PASS      |

# 3. Historias de Usuario del Proyecto

Las siguientes historias de usuario componen el Product Backlog del proyecto. Cada una cuenta con pruebas automatizadas que validan su comportamiento esperado.

| ID    | Módulo        | Historia de Usuario                     | Valor de Negocio                  | Grupo    |
|-------|---------------|-----------------------------------------|-----------------------------------|----------|
| HU-01 | Autenticación | Como usuario, quiero iniciar sesión con | Garantizar la confidencialidad de | Módulo 1 |

| ID    | Módulo        | Historia de Usuario                                                            | Valor de Negocio                                                  | Grupo    |
|-------|---------------|--------------------------------------------------------------------------------|-------------------------------------------------------------------|----------|
|       |               | correo, contraseña y código TOTP de 6 dígitos                                  | los datos de la olla y el padrón                                  |          |
| HU-02 | Autenticación | Como usuario autenticado, quiero cerrar mi sesión de forma explícita y segura  | Evitar accesos no autorizados si el dispositivo queda desatendido | Módulo 1 |
| HU-03 | Móvil PWA     | Como lideresa, quiero ver un dashboard móvil con navegación inferior funcional | Acceder rápido a padrón, inventario, alertas y menú               | Módulo 2 |
| HU-04 | Móvil PWA     | Como lideresa, quiero consultar y buscar beneficiarios en el padrón móvil      | Verificar datos antes de entregar raciones                        | Módulo 2 |
| HU-05 | Móvil PWA     | Como lideresa, quiero registrar nuevos beneficiarios desde el celular          | Mantener el padrón actualizado ante nuevos comensales             | Módulo 2 |
| HU-06 | Móvil PWA     | Como lideresa, quiero ver el inventario y registrar entradas de insumos        | Controlar el abastecimiento por donaciones o compras              | Módulo 2 |
| HU-07 | Móvil PWA     | Como lideresa, quiero generar sugerencias de menú con IA según mi stock        | Diseñar menús balanceados según disponibilidad real               | Módulo 2 |
| HU-08 | Móvil PWA     | Como lideresa, quiero registrar la entrega de raciones de forma masiva         | Llevar control estadístico exacto de raciones por día             | Módulo 2 |
| HU-09 | Web Admin     | Como administrador, quiero ver un dashboard con KPIs globales y gráficos       | Tomar decisiones de abastecimiento basadas en datos reales        | Módulo 3 |
| HU-10 | Web Admin     | Como administrador, quiero navegar el menú lateral sin retrasos                | Gestionar ágilmente las áreas administrativas                     | Módulo 3 |
| HU-11 | Web Admin     | Como administrador, quiero buscar y filtrar el padrón consolidado              | Auditar el padrón completo de la jurisdicción                     | Módulo 3 |
| HU-12 | Web Admin     | Como administrador, quiero crear, editar y eliminar beneficiarios              | Garantizar consistencia del padrón municipal                      | Módulo 3 |
| HU-13 | Web Admin     | Como administrador, quiero crear y listar                                      | Mantener aislamiento de datos por municipalidad                   | Módulo 3 |

| ID           | Módulo      | Historia de Usuario                                                     | Valor de Negocio                                    | Grupo    |
|--------------|-------------|-------------------------------------------------------------------------|-----------------------------------------------------|----------|
|              |             | organizaciones (tenants)                                                |                                                     |          |
| <b>HU-14</b> | Web Admin   | Como administrador, quiero registrar ollas comunes en mi organización   | Ampliar cobertura de puntos de distribución         | Módulo 3 |
| <b>HU-15</b> | Web Admin   | Como usuario, quiero editar mi perfil y cambiar el tema visual          | Personalizar mi experiencia de trabajo              | Módulo 3 |
| <b>HU-16</b> | Offline PWA | Como lideresa, quiero trabajar offline y sincronizar al recuperar señal | Evitar pérdida de datos y doble digitación en campo | Módulo 4 |

## 4. Casos de Prueba – Escenarios de Éxito

A continuación se listan todos los casos de prueba automatizados que validan el comportamiento correcto del sistema por cada historia de usuario.

### 4.1 HU-01 y HU-02 – Autenticación y Sesión

| ID     | Historia | Descripción de la Prueba                                                    | Suite     | Herramienta | Resultado |
|--------|----------|-----------------------------------------------------------------------------|-----------|-------------|-----------|
| F-06   | HU-01    | Autenticación: login con credenciales correctas, retorna estado MFA_PENDING | Funcional | Vitest      | PASS      |
| E-01.3 | HU-01    | Login exitoso con código TOTP dinámico, redirige al dashboard móvil         | E2E Móvil | Playwright  | PASS      |
| E-04   | HU-02    | Botón de Salir cierra la sesión y redirige al login                         | E2E Móvil | Playwright  | PASS      |

### 4.2 HU-03 a HU-05 – Dashboard, Padrón y Registro Móvil

| ID     | Historia | Descripción de la Prueba                                             | Suite     | Herramienta | Resultado |
|--------|----------|----------------------------------------------------------------------|-----------|-------------|-----------|
| E-02   | HU-03    | Dashboard móvil muestra información correcta de la Olla Común activa | E2E Móvil | Playwright  | PASS      |
| E-03   | HU-03    | Barra de navegación inferior cambia de vista correctamente           | E2E Móvil | Playwright  | PASS      |
| F-01   | HU-04    | Creación básica de beneficiario con campos obligatorios              | Funcional | Vitest      | PASS      |
| E-05   | HU-04    | Padrón de beneficiarios carga el listado correctamente               | E2E Móvil | Playwright  | PASS      |
| E-06   | HU-04    | Búsqueda de beneficiarios filtra resultados en tiempo real           | E2E Móvil | Playwright  | PASS      |
| F-02   | HU-05    | Restricción correcta de DNI duplicado al registrar beneficiario      | Funcional | Vitest      | PASS      |
| E-07.2 | HU-05    | Creación exitosa de un nuevo beneficiario desde el formulario móvil  | E2E Móvil | Playwright  | PASS      |

### 4.3 HU-06 – Gestión de Inventario Móvil

| ID     | Historia | Descripción de la Prueba                                                     | Suite             | Herramienta | Resultado |
|--------|----------|------------------------------------------------------------------------------|-------------------|-------------|-----------|
| F-10   | HU-06    | Inventario: registro de movimiento de ingreso (In) correctamente             | Funcional         | Vitest      | PASS      |
| F-11   | HU-06    | Inventario: registro de movimiento de egreso (Out) correctamente             | Funcional         | Vitest      | PASS      |
| F-12   | HU-06    | Egreso de inventario sin stock suficiente: permitido con alerta (no bloquea) | Funcional         | Vitest      | PASS      |
| I-13   | HU-06    | Cálculo automático de alertas de stock bajo el límite mínimo configurado     | Interoperabilidad | Vitest      | PASS      |
| E-08   | HU-06    | Inventario muestra correctamente la lista de stock actual                    | E2E Móvil         | Playwright  | PASS      |
| E-09.1 | HU-06    | Registro de movimiento de ingreso en Inventario desde la vista móvil         | E2E Móvil         | Playwright  | PASS      |

#### 4.4 HU-07 y HU-08 – Menú IA y Entrega de Raciones

| ID   | Historia | Descripción de la Prueba                                                   | Suite             | Herramienta | Resultado |
|------|----------|----------------------------------------------------------------------------|-------------------|-------------|-----------|
| F-13 | HU-07    | Menú IA: simulación de raciones e ingredientes según stock disponible      | Funcional         | Vitest      | PASS      |
| I-14 | HU-07    | Integración del recomendador de recetas IA con JSON Schema consistente     | Interoperabilidad | Vitest      | PASS      |
| E-10 | HU-07    | Panel de sugerencias de Menú IA se carga correctamente en vista móvil      | E2E Móvil         | Playwright  | PASS      |
| E-11 | HU-07    | Solicitar nueva sugerencia de Menú IA genera respuesta válida              | E2E Móvil         | Playwright  | PASS      |
| F-14 | HU-08    | Entregas: registro múltiple de raciones a beneficiarios                    | Funcional         | Vitest      | PASS      |
| E-12 | HU-08    | Registro de entrega de raciones desde panel interactivo de despacho diario | E2E Móvil         | Playwright  | PASS      |

#### 4.5 HU-09 a HU-11 – Dashboard Web y Padrón Administrativo

| ID     | Historia | Descripción de la Prueba                                                   | Suite         | Herramienta | Resultado |
|--------|----------|----------------------------------------------------------------------------|---------------|-------------|-----------|
| F-15   | HU-09    | Dashboard: consolidación correcta de métricas globales (KPIs)              | Funcional     | Vitest      | PASS      |
| E-13   | HU-09    | Dashboard web carga correctamente con KPIs, gráficos e indicadores         | E2E Workspace | Playwright  | PASS      |
| E-14.1 | HU-10    | Navegación del Sidebar funciona correctamente entre secciones              | E2E Workspace | Playwright  | PASS      |
| E-15   | HU-11    | Listado de Beneficiarios se muestra correctamente en el workspace          | E2E Workspace | Playwright  | PASS      |
| E-16   | HU-11    | Búsqueda de Beneficiarios filtra resultados por nombre o DNI               | E2E Workspace | Playwright  | PASS      |
| E-17   | HU-11    | Filtro de Beneficiarios por Olla Común reduce correctamente los resultados | E2E Workspace | Playwright  | PASS      |

#### 4.6 HU-12 – Mantenimiento de Beneficiarios (CRUD Web)

| ID     | Historia | Descripción de la Prueba                                              | Suite         | Herramienta | Resultado |
|--------|----------|-----------------------------------------------------------------------|---------------|-------------|-----------|
| F-03   | HU-12    | Actualización correcta del nivel de prioridad del beneficiario        | Funcional     | Vitest      | PASS      |
| F-04   | HU-12    | Asignación y guardado correcto del perfil médico del beneficiario     | Funcional     | Vitest      | PASS      |
| F-05   | HU-12    | Eliminación física/lógica del beneficiario confirmada                 | Funcional     | Vitest      | PASS      |
| E-18.2 | HU-12    | Registro exitoso de beneficiario desde el formulario web              | E2E Workspace | Playwright  | PASS      |
| E-19   | HU-12    | Edición de Beneficiario refleja los cambios correctamente en la tabla | E2E Workspace | Playwright  | PASS      |
| E-20   | HU-12    | Eliminación de Beneficiario confirmada y removida de la base de datos | E2E Workspace | Playwright  | PASS      |

#### 4.7 HU-13 y HU-14 – Organizaciones y Ollas Comunes

| ID     | Historia | Descripción de la Prueba                                            | Suite             | Herramienta | Resultado |
|--------|----------|---------------------------------------------------------------------|-------------------|-------------|-----------|
| I-03   | HU-13    | Consulta de Organizaciones (Multi-tenant) responde correctamente    | Interoperabilidad | Vitest      | PASS      |
| I-05   | HU-13    | Aislamiento RLS en base de datos garantiza separación entre tenants | Interoperabilidad | Vitest      | PASS      |
| E-21   | HU-13    | Listado de Organizaciones se muestra correctamente                  | E2E Workspace     | Playwright  | PASS      |
| E-22.1 | HU-13    | Creación de nueva organización genera slug único correctamente      | E2E Workspace     | Playwright  | PASS      |
| I-04   | HU-14    | Consulta de Ollas Comunes asociadas a una organización              | Interoperabilidad | Vitest      | PASS      |
| E-23   | HU-14    | Creación de Olla Común se persiste y refleja en la grilla visual    | E2E Workspace     | Playwright  | PASS      |

## 4.8 HU-15 – Perfil y Preferencias de Usuario

| ID     | Historia | Descripción de la Prueba                                             | Suite         | Herramienta | Resultado |
|--------|----------|----------------------------------------------------------------------|---------------|-------------|-----------|
| E-24.1 | HU-15    | Edición de datos del perfil de usuario se guarda correctamente       | E2E Workspace | Playwright  | PASS      |
| E-25   | HU-15    | Cambio de tema (Claro/Oscuro) se aplica correctamente en la interfaz | E2E Workspace | Playwright  | PASS      |
| E-26   | HU-15    | Sección de Configuración muestra los enlaces de acceso correctamente | E2E Workspace | Playwright  | PASS      |

## 4.9 HU-16 – Sincronización Offline y Resiliencia PWA

| ID   | Historia | Descripción de la Prueba                                                    | Suite       | Herramienta | Resultado |
|------|----------|-----------------------------------------------------------------------------|-------------|-------------|-----------|
| E-31 | HU-16    | Registro offline de beneficiario con reconexión y sincronización automática | Offline PWA | Playwright  | PASS      |
| E-32 | HU-16    | Registro offline de entrega de ración con sincronización al reconectar      | Offline PWA | Playwright  | PASS      |

| ID          | Historia | Descripción de la Prueba                                                    | Suite       | Herramienta | Resultado   |
|-------------|----------|-----------------------------------------------------------------------------|-------------|-------------|-------------|
| <b>E-33</b> | HU-16    | Registro offline de movimiento de inventario con sincronización automática  | Offline PWA | Playwright  | <b>PASS</b> |
| <b>E-34</b> | HU-16    | Control de conflictos de sincronización (DNI duplicado) sin atascar la cola | Offline PWA | Playwright  | <b>PASS</b> |

## 4.10 Autenticación y Seguridad (Transversal)

Las siguientes pruebas cubren el flujo de autenticación multifactor (MFA/TOTP), aislamiento de datos por organización (multi-tenant) y controles de seguridad.

| ID          | Historia | Descripción de la Prueba                                                                              | Suite             | Herramienta | Resultado   |
|-------------|----------|-------------------------------------------------------------------------------------------------------|-------------------|-------------|-------------|
| <b>F-06</b> | Auth     | Flujo de login exitoso, verificando paso inicial de MFA (retorna token temporal y estado MFA_PENDING) | Funcional         | Vitest      | <b>PASS</b> |
| <b>F-07</b> | Auth     | Rechazo de acceso ante envío de contraseña incorrecta (401 Unauthorized)                              | Funcional         | Vitest      | <b>PASS</b> |
| <b>F-08</b> | Auth     | Rechazo de acceso ante correo electrónico no registrado                                               | Funcional         | Vitest      | <b>PASS</b> |
| <b>F-09</b> | Auth     | Validación de código TOTP incorrecto y rechazo de autenticación MFA                                   | Funcional         | Vitest      | <b>PASS</b> |
| <b>I-01</b> | Auth     | Interconexión activa con base de datos PostgreSQL mediante Prisma (GET /api/health/prisma)            | Interoperabilidad | Vitest      | <b>PASS</b> |
| <b>I-02</b> | Auth     | Conectividad y respuesta del SDK de Supabase Client en la nube (GET /api/health/supabase)             | Interoperabilidad | Vitest      | <b>PASS</b> |
| <b>I-05</b> | Auth     | Garantía de aislamiento multi-tenant por RLS: un tenant no puede ver beneficiarios de otro            | Interoperabilidad | Vitest      | <b>PASS</b> |
| <b>I-06</b> | Auth     | Funcionamiento del middleware de Rate Limiting: bloqueo automático tras 5                             | Interoperabilidad | Vitest      | <b>PASS</b> |

| ID   | Historia | Descripción de la Prueba                                                                       | Suite             | Herramienta | Resultado |
|------|----------|------------------------------------------------------------------------------------------------|-------------------|-------------|-----------|
|      |          | llamadas de login/min (429)                                                                    |                   |             |           |
| I-07 | Auth     | Cabeceras CORS válidas presentes en las respuestas del API Gateway                             | Interoperabilidad | Vitest      | PASS      |
| I-11 | Auth     | Almacenamiento seguro del secreto TOTP de 2FA en base de datos (totpSecret en tabla app_users) | Interoperabilidad | Vitest      | PASS      |
| E-01 | Auth     | Login con credenciales inválidas muestra mensaje de error en vista móvil                       | E2E Móvil         | Playwright  | PASS      |
| E-02 | Auth     | MFA con código TOTP inválido rechaza el acceso correctamente                                   | E2E Móvil         | Playwright  | PASS      |
| E-03 | Auth     | Login exitoso con TOTP dinámico redirige al dashboard móvil                                    | E2E Móvil         | Playwright  | PASS      |
| E-06 | Auth     | Botón de Salir cierra la sesión correctamente y redirige al login                              | E2E Móvil         | Playwright  | PASS      |

## 4.11 Usabilidad y Accesibilidad

Auditorías automatizadas sobre el código fuente del frontend (Next.js). Puntajes obtenidos: Accesibilidad 96/100 · Buenas Prácticas 100/100 · Rendimiento 98/100 · SEO 100/100.

| ID   | Historia   | Descripción de la Prueba                                                      | Suite      | Herramienta | Resultado |
|------|------------|-------------------------------------------------------------------------------|------------|-------------|-----------|
| U-01 | Usabilidad | Ratio de contraste de color (WCAG AA): contraste adecuado entre texto y fondo | Usabilidad | Lighthouse  | PASS      |
| U-02 | Usabilidad | Etiquetas alternativas (alt) presentes en todos los elementos de imagen       | Usabilidad | Lighthouse  | PASS      |
| U-03 | Usabilidad | Estructura semántica de headings H1-H6 correcta y jerarquía coherente         | Usabilidad | Lighthouse  | PASS      |
| U-04 | Usabilidad | Atributos ARIA y etiquetas descriptivas en todos los formularios              | Usabilidad | Lighthouse  | PASS      |
| U-05 | Usabilidad | Accesibilidad de navegación por teclado (tabindex ordenado)                   | Usabilidad | Lighthouse  | PASS      |

| ID   | Historia   | Descripción de la Prueba                                                             | Suite      | Herramienta | Resultado |
|------|------------|--------------------------------------------------------------------------------------|------------|-------------|-----------|
| U-06 | Usabilidad | Responsividad de la cuadrícula visual en pantallas de 360px (gama baja)              | Usabilidad | Lighthouse  | PASS      |
| U-07 | Usabilidad | Validaciones y avisos en tiempo real en inputs del padrón de beneficiarios           | Usabilidad | Lighthouse  | PASS      |
| U-08 | Usabilidad | Detección automática de formato de e-mail inválido en caja de login                  | Usabilidad | Lighthouse  | PASS      |
| U-09 | Usabilidad | Tiempo de carga visual inicial (FCP) < 1.8 segundos para redes lentas                | Usabilidad | Lighthouse  | PASS      |
| U-10 | Usabilidad | Elementos de espera (loaders/spinners) visibles durante cargas lentas de la API      | Usabilidad | Lighthouse  | PASS      |
| U-11 | Usabilidad | Retroalimentación instantánea mediante mensajes emergentes flotantes (Sonner toasts) | Usabilidad | Lighthouse  | PASS      |
| U-12 | Usabilidad | Confirmación emergente antes de realizar operaciones de eliminación                  | Usabilidad | Lighthouse  | PASS      |
| U-13 | Usabilidad | Persistencia del token JWT en localStorage tras refrescar la página                  | Usabilidad | Lighthouse  | PASS      |
| U-14 | Usabilidad | Deshabilitación de botones durante el proceso de envío para prevenir doble inserción | Usabilidad | Lighthouse  | PASS      |
| U-15 | Usabilidad | Adaptabilidad visual completa al alternar entre modo claro y oscuro                  | Usabilidad | Lighthouse  | PASS      |

## 5. Casos de Prueba – Escenarios de Falla Controlada

Los siguientes 40 casos verifican que el sistema responde correctamente ante entradas inválidas, condiciones de borde y errores esperados. Todos los escenarios están controlados: el sistema rechaza o gestiona la situación de forma segura sin fallos catastróficos. Estos casos fueron desarrollados como complemento directo de los escenarios de éxito, cubriendo validaciones de datos, control de acceso, multi-tenant y seguridad.

| ID      | Historia | Escenario de Falla                                                       | Dato de Entrada               | Resultado Esperado                                         | Estado     |
|---------|----------|--------------------------------------------------------------------------|-------------------------------|------------------------------------------------------------|------------|
| F-01.f1 | HU-04/05 | Registro con nombres y apellidos obligatorios vacíos o nulos             | nombres: "", apellidos: null  | Error 400: Campos obligatorios faltantes                   | CONTROLADO |
| F-01.f2 | HU-04/05 | Registro con fecha de nacimiento futura                                  | fechaNacimiento: '2030-01-01' | Error 400: Fecha de nacimiento inválida                    | CONTROLADO |
| F-01.f3 | HU-04/05 | Registro con formato de fecha inválido                                   | fechaNacimiento: '31-13-2024' | Error 400: Formato de fecha incorrecto                     | CONTROLADO |
| F-01.f4 | HU-04/05 | Registro con DNI extremadamente largo                                    | dni: '123456789012345'        | Error 400: DNI excede longitud permitida                   | CONTROLADO |
| F-01.f5 | HU-04/05 | Registro de beneficiario sin DNI                                         | dni: undefined                | Error 400: El DNI es obligatorio                           | CONTROLADO |
| F-01.f6 | HU-04/05 | Registro de beneficiario sin Olla Común asociada                         | ollaComunId: null             | Error 400: Debe asociarse a una Olla Común                 | CONTROLADO |
| F-01.f7 | HU-04/05 | Registro sin cabecera de autorización                                    | Authorization: (ausente)      | Error 401: No autorizado                                   | CONTROLADO |
| E-07.1  | HU-05    | Formulario móvil de nuevo beneficiario sin completar campos obligatorios | nombres y apellidos vacíos    | Mensajes de validación visibles, no se envía el formulario | CONTROLADO |
| E-07.3  | HU-05    | Registrar beneficiario con DNI ya existente desde móvil                  | dni: '71829384' (duplicado)   | Error visible: DNI ya registrado en el padrón              | CONTROLADO |
| E-18.1  | HU-12    | Formulario web de beneficiario sin completar                             | campos requeridos vacíos      | Alertas de validación                                      | CONTROLADO |

| ID             | Historia | Escenario de Falla                                              | Dato de Entrada                               | Resultado Esperado                        | Estado            |
|----------------|----------|-----------------------------------------------------------------|-----------------------------------------------|-------------------------------------------|-------------------|
|                |          | campos obligatorios                                             |                                               | visibles en el formulario                 |                   |
| <b>E-18.3</b>  | HU-12    | Registrar beneficiario con formato de DNI inválido (letras)     | dni: 'ABCD1234'                               | Error visible: formato de DNI inválido    | <b>CONTROLADO</b> |
| <b>F-03.f1</b> | HU-12    | Actualización de prioridad de beneficiario inexistente          | id: 'no-existe-999'                           | Error 404: Beneficiario no encontrado     | <b>CONTROLADO</b> |
| <b>F-03.f2</b> | HU-12    | Actualización con valor de prioridad inválido                   | priorityLevel: 'critico' (no en enum)         | Error 400: Valor de prioridad inválido    | <b>CONTROLADO</b> |
| <b>F-04.f1</b> | HU-12    | Asignación de condición médica con IDs inexistentes o inválidos | medicalConditionIds: ['id-falso']             | Error 400: Condición médica no encontrada | <b>CONTROLADO</b> |
| <b>F-05.f1</b> | HU-12    | Eliminación de beneficiario con ID mal formado                  | id: '!!!123'                                  | Error 400: Identificador inválido         | <b>CONTROLADO</b> |
| <b>E-01.1</b>  | HU-01    | Login con credenciales inválidas desde la vista móvil           | email/contraseña incorrectos                  | Mensaje de error visible, acceso denegado | <b>CONTROLADO</b> |
| <b>E-01.2</b>  | HU-01    | MFA con código TOTP inválido                                    | código TOTP: '000000'                         | Acceso denegado y advertencia al usuario  | <b>CONTROLADO</b> |
| <b>E-01.4</b>  | HU-01    | Acceso a ruta móvil protegida sin autenticación                 | sin sesión activa, navega a /mobile/dashboard | Redirección automática al login           | <b>CONTROLADO</b> |
| <b>F-06.f1</b> | HU-01    | Login con campos faltantes (email o contraseña vacíos)          | email: "", password: ""                       | Error 400: Campos obligatorios faltantes  | <b>CONTROLADO</b> |
| <b>F-09.f1</b> | HU-01    | Control MFA: bloqueo tras varios intentos fallidos de OTP       | 5 intentos consecutivos con OTP incorrecto    | Error 429: Cuenta bloqueada temporalmente | <b>CONTROLADO</b> |
| <b>E-14.2</b>  | HU-10    | Acceso a ruta del workspace protegida sin autenticación         | sin sesión activa, navega a /workspace        | Redirección automática al login           | <b>CONTROLADO</b> |
| <b>F-10.f1</b> | HU-06    | Registro de ingreso de                                          | cantidad: -5                                  | Error 400: La cantidad debe               | <b>CONTROLADO</b> |

| ID             | Historia | Escenario de Falla                                                 | Dato de Entrada                        | Resultado Esperado                                | Estado            |
|----------------|----------|--------------------------------------------------------------------|----------------------------------------|---------------------------------------------------|-------------------|
|                |          | inventario con cantidad negativa                                   |                                        | ser mayor a cero                                  |                   |
| <b>F-10.f2</b> | HU-06    | Registro de ingreso de inventario con cantidad cero                | cantidad: 0                            | Error 400: La cantidad debe ser mayor a cero      | <b>CONTROLADO</b> |
| <b>F-10.f3</b> | HU-06    | Registro de movimiento para un insumo inexistente                  | insumoid: 'no-existe'                  | Error 404: Insumo no encontrado                   | <b>CONTROLADO</b> |
| <b>F-11.f1</b> | HU-06    | Registro de egreso de inventario con cantidad menor o igual a cero | cantidad: -1                           | Error 400: Cantidad inválida para egreso          | <b>CONTROLADO</b> |
| <b>E-09.2</b>  | HU-06    | Intento de avanzar en el flujo de inventario con datos vacíos      | formulario incompleto en el stepper    | No se permite avanzar, valida campos obligatorios | <b>CONTROLADO</b> |
| <b>F-13.f1</b> | HU-07    | Plan de menú generado con raciones negativas                       | raciones: -10                          | Error 400: Las raciones deben ser mayor a cero    | <b>CONTROLADO</b> |
| <b>F-14.f1</b> | HU-08    | Registro de entregas con lista vacía de beneficiarios              | beneficiarios: []                      | Error 400: Debe incluir al menos un beneficiario  | <b>CONTROLADO</b> |
| <b>F-15.f1</b> | HU-09    | Acceso al dashboard con token de sesión corrupto                   | Authorization: 'Bearer token-corrupto' | Error 401: Token inválido, acceso denegado        | <b>CONTROLADO</b> |
| <b>I-03.f1</b> | HU-13    | Consulta de organizaciones sin token Bearer                        | sin cabecera Authorization             | Error 401: No autorizado                          | <b>CONTROLADO</b> |
| <b>I-03.f2</b> | HU-13    | Consulta de organizaciones con token inválido                      | token: 'invalido-123'                  | Error 401: Token inválido                         | <b>CONTROLADO</b> |
| <b>I-04.f1</b> | HU-14    | Consulta de ollas comunes para slug de organización inexistente    | slug: 'no-existe'                      | Error 404: Organización no encontrada             | <b>CONTROLADO</b> |
| <b>I-05.f1</b> | HU-13    | Intento de acceso cruzado                                          | tenant A solicita datos de tenant B    | Error 403: Acceso denegado por                    | <b>CONTROLADO</b> |

| ID      | Historia | Escenario de Falla                                              | Dato de Entrada                                       | Resultado Esperado                                     | Estado     |
|---------|----------|-----------------------------------------------------------------|-------------------------------------------------------|--------------------------------------------------------|------------|
|         |          | a datos de otro tenant                                          |                                                       | aislamiento RLS                                        |            |
| I-07.f1 | Auth     | Petición CORS desde un origen no permitido                      | Origin: 'https://sitio-malicioso.com'                 | Bloqueo de la petición por política CORS               | CONTROLADO |
| I-11.f1 | Auth     | Secreto TOTP corrupto o ausente en base de datos                | totpSecret: null                                      | Error 500 controlado: solicita re-configuración de MFA | CONTROLADO |
| I-12.f1 | HU-07    | Subida de archivo a Supabase Storage con extensión no permitida | archivo.exe                                           | Error 400: Tipo de archivo no permitido                | CONTROLADO |
| I-12.f2 | HU-07    | Subida de archivo vacío a Supabase Storage                      | archivo de 0 bytes                                    | Error 400: El archivo no puede estar vacío             | CONTROLADO |
| I-13.f1 | HU-06    | Consulta de alertas de stock con rol no autorizado              | token de rol 'lideresa' solicitando endpoint de admin | Error 403: Rol no autorizado                           | CONTROLADO |
| E-22.2  | HU-13    | Crear organización con nombre vacío                             | nombre: "                                             | Validación visible: el nombre es obligatorio           | CONTROLADO |
| E-24.2  | HU-15    | Edición de perfil con correo electrónico inválido               | email: 'correo-no-valido'                             | Validación visible: formato de correo incorrecto       | CONTROLADO |

## 6. Resumen de Cobertura

| Suite de Pruebas                            | Herramienta | Total Casos | PASS       | % Cobertura |
|---------------------------------------------|-------------|-------------|------------|-------------|
| Funcional (F-01 a F-15 + variantes)         | Vitest      | 35          | 35         | 100%        |
| Interoperabilidad (I-01 a I-15 + variantes) | Vitest      | 24          | 24         | 100%        |
| Usabilidad/Accesibilidad (U-01 a U-15)      | Lighthouse  | 15          | 15         | 100%        |
| E2E Móvil (Test 01 a 12 + variantes)        | Playwright  | 18          | 18         | 100%        |
| E2E Workspace (Test 13 a 26 + variantes)    | Playwright  | 19          | 19         | 100%        |
| Offline PWA (4 escenarios E2E)              | Playwright  | 4           | 4          | 100%        |
| <b>TOTAL GENERAL</b>                        | —           | <b>115</b>  | <b>115</b> | <b>100%</b> |

## 7. Pruebas de Seguridad (DAST – OWASP ZAP)

Como complemento a las pruebas funcionales y de usabilidad, se ejecutó una prueba de seguridad dinámica (DAST – Dynamic Application Security Testing) utilizando OWASP ZAP (Zed Attack Proxy) v2.17.0 contra la aplicación desplegada en Vercel.

A diferencia de un análisis estático de código, DAST evalúa la aplicación en ejecución desde la perspectiva de un atacante externo, mediante dos fases: rastreo automático de rutas (Spider) y ataques controlados contra cada endpoint descubierto (Active Scan).

### 7.1 Cobertura de Vulnerabilidades Evaluadas

El escaneo verificó la aplicación contra las categorías del OWASP Top 10 y OWASP ASVS, incluyendo:

- Inyección SQL (MySQL, PostgreSQL, Oracle) y SQL Injection ciego
- Cross-Site Scripting (XSS) reflejado y almacenado
- Configuración incorrecta de CORS (Cross-Domain Misconfiguration)
- Exposición de información sensible (.env, código fuente, directorios)
- Cabeceras de seguridad faltantes (CSP, HSTS, X-Frame-Options)
- Path Traversal, Remote File Include y Server Side Include
- Vulnerabilidades conocidas en librerías JavaScript (Retire.js)

### 7.2 Resultados del Escaneo

El escaneo activo contra la aplicación desplegada arrojó las siguientes alertas:

| Nivel de Riesgo | Alerta Detectada                             | Acción Correctiva                                                                                             |
|-----------------|----------------------------------------------|---------------------------------------------------------------------------------------------------------------|
| Medium          | Content Security Policy (CSP) Header Not Set | Agregar cabecera Content-Security-Policy en la configuración de Vercel (vercel.json) o en el servidor Next.js |
| Medium          | Cross-Domain Misconfiguration (CORS: *)      | Restringir Access-Control-Allow-Origin a dominios específicos en la configuración del backend                 |
| Informational   | Retrieved from Cache                         | Revisar cabeceras de caché (Cache-Control, Pragma) en recursos estáticos                                      |
| Informational   | User Agent Fuzzer                            | Hallazgo generado por el propio escaneo; no representa riesgo real                                            |

No se detectaron vulnerabilidades de nivel High (crítico). Los hallazgos de nivel Medium corresponden a configuraciones de cabeceras HTTP recomendadas como buena práctica, no a fallos explotables que comprometan la confidencialidad o integridad de los datos del sistema.

### 7.3 Resumen de la Prueba

| Hallazgos High | Hallazgos Medium | Hallazgos Informational |
|----------------|------------------|-------------------------|
| 0              | 2                | 2                       |

Herramienta: OWASP ZAP v2.17.0 (Docker, modo headless) · Tipo de prueba: DAST · Objetivo: aplicación desplegada en Vercel · Técnicas: Spider + Active Scan.

## 8. Conclusiones

El proyecto SIGO-OLLAS cuenta con una suite de 115 pruebas automatizadas que cubre 16 historias de usuario distribuidas en 4 módulos funcionales: Autenticación, Módulo Móvil PWA, Módulo Web Administrativo, y Sincronización Offline. La arquitectura de pruebas utiliza Vitest para el backend (59 casos) y Playwright para el frontend (41 casos), incluyendo escenarios offline-first críticos para el contexto de uso real (zonas rurales de conectividad limitada).

Las pruebas de usabilidad confirman que la interfaz cumple con los estándares WCAG 2.1 AA de accesibilidad y un rendimiento de carga superior al umbral establecido ( $FCP < 1.8s$ ), garantizando una experiencia adecuada en dispositivos de gama baja. Los 40 escenarios de falla controlada validan que el sistema gestiona errores de forma segura sin interrupciones críticas del servicio, cubriendo validaciones de datos, control de acceso por roles y aislamiento multi-tenant.

La prueba de seguridad dinámica (DAST) con OWASP ZAP confirma que la aplicación no presenta vulnerabilidades críticas (0 hallazgos de nivel High), validando la robustez de la arquitectura frente a ataques externos comunes como inyección SQL, XSS y exposición de información sensible.